

Bezpečnostné problémy v sieťach

- **Dôvernosť** -ochrana prenasaných dát, vie ich precitať iba prijímateľ
- **integrita a autentickosť**
 - -aby nebolo možné dáta nepozorovane poškodiť
 - -čize prídu také ako boli odoslané
 - -v súčasnosti ...ak ich niekto zmení, viem o tom, ale neviem tomu zabrániť
 - - chcem mať istotu, že tá správa prišla naozaj od toho príjemcu
- **Dostupnosť** viem sa k dátam dostať vtedy, keď potrebujem
- **autentifikácia**
 - používateľov
 - systémov
- **riadenie prístupu** pre koho sú dáta prístupné

Bezpečnostné mechanizmy

- fyzická ochrana prístupu
- riadenie prístupu, oddelenie komunikácie
 - napríklad aj kable na chodbe, ktoré niekto môže poškodiť
- kryptografia
 - šifrovanie
 - symetrické (DES, 3DES, AES, ...)
obe strany potrebujú poznať KLUC
 - asymetrické (PKI) (RSA, ...)
su DVA kľúče: súkromný a verejný. Súkromný poznám iba ja a verejný kľúč poznajú všetci (zasifrujem ho verejným kľúčom a ja si ho mojim súkromným desifrujem)
 - digitálny podpis (RSA, DSS, ...)
 - hašovacie funkcie s kľúčom (HMAC-SHA1, ...)
- organizačné opatrenia

Problém distribúcie kľúčov

- symetrická kryptografia

- potreba zdieľaného tajného kľúča

musia ho poznať len DVAJA ľudia. Sú algoritmy, ktoré to vedú vypočítať z hodnôt, ktoré majú strany, nikto iný ale nevie vypočítať hodnotu tohto kľúča (ak to niekto sleduje)

- algoritmy (napr. Diffie-Hellman) na výpočet zdieľaného tajného kľúča

- potreba vzájomnej autentifikácie na vylúčenie Man-In-the-Middle útoku

ak niekto preruší komunikáciu medzi dvoma a tvári sa, že on je ten, koho považujeme za prijemcu a s každým si dohodne kľúč a vyzera to tak, že všetko funguje správne ("Muz v strede")

- generovanie kľúča jednou stranou a bezpečný prenos druhej strane

- asymetrická kryptografia

- distribúcia verejných kľúčov

musíme vedieť, či to kľúč je.... podľa toho vieme overiť, od koho to je

- certifikáty

Bezpečnosť na linkovej vrstve

- fyzická ochrana káblov a sieťových komponentov
- separácia sietí na fyzickej vrstve

Príklad: máme dve siete, ktorými sa šíria citlivé a nebezpečné informácie...ak ich odseparujeme, nedá sa medzi nimi komunikovať

- často nefunguje proti vnútornému nepriateľovi
 - keď sa viem dostať k počítaču, viem sa dostať ku káblu
 - použiteľné v kombinácii s organizačnými opatreniami
- nekryptografická
 - VLAN (virtual LAN)
 - separácia sietí na linkovej vrstve vieme povedať, ktorý port patrí do ktorej odseparovanej siete (nemusíme to robiť cez nové káble)
 - riadenie prístupu k portu
 - na báze linkovej adresy tu si ale útočník vie zmeniť linkovú adresu, na tú, ktorá je povolená a jednoducho sa vie dostať k portu
 - IEEE 802.1X

Bezpečnosť na linkovej vrstve

- kryptografická
 - šifrovanie, kontrola autenticity, autentifikácia
 - známe vo WiFi svete
 - WEP, WPA, WPA2

WEP

- zastaralé zabezpečenie bezdrôtovej siete
- Šifra generuje pseudonáhodný prúd bajtov, ktorý je spájaný s čistým textom prostredníctvom operácie XOR. Dešifrovanie prebieha na podobnom princípe, ale naopak.
- s lepším hardverom sa dá tento kľuč zistiť za pár minút
- už sa nevyužíva

WPA

- zachováva algoritmy, ale rieši problémy zWEP kde sa dal odhaliť kľuč
- útočník na prelomenie WPA používa slovníkový útok alebo „hrubú silu“.

WPA2

- každý používateľ má vlastnú autentifikáciu (meno a heslo)
- dohodne sa šifrovanie
- teraz najviac využívaný
- je to bezpečné, treba si ale zvoliť dlhšie a zložitejšie heslo aby sa nedalo uhadnúť

VLAN (IEEE 802.1Q)

- VLAN je skupina hostov (počítačov, serverov,...), ktorí spolu komunikujú akoby boli na jednej broadcastovej doméne bez ohľadu na ich fyzickú konektivitu. VLAN má rovnaké vlastnosti ako fyzická LAN, ale umožňuje aby sa koncové stanice spájali dokopy, aj keď nie sú v jednom sieťovom prepínači (switch-i).
- každá sieť ma identifikátor VLAN ID – skr. VID
- príslušnosť rámca k VLAN
 - tagged frame – podľa údajov v hlavičke
vklada sa hlavicka navyse ktora hovorí kam ramec patri
 - untagged frame – podľa portu (PVID)
- switch
 - pre každý port musí poznať: Port VID (PVID), množina VID (zoznam zariadení, ktoré môžu)
 - pošle rámec len na porty danej VLAN (Egress filtering)
 - **môže** filtrovať rámce z VLAN, do ktorej zdrojový port nepatrí (Ingress filtering)

Bezpečnosť na sieťovej vrstve

- firewall

- filtrácia komunikácie – riadenie prístupu
- stateless vs. statefull, NAT

STATELESS – o každom pakete sa rozhoduje samostatne

STATEFULL- Stavový firewall je schopný rozlišovať rôzne stavy paketů v rámci jednotlivých relací (spojení) a jeho úkolem je propustit pouze takové, které patří do již povolené relace (jiné jsou zamítnuty).

- deny vs. allow by default

- VPN

- šifrovanie, kontrola autentickosti, riadenie prístupu
- IPSec (AH, ESP)
- OpenVPN (IP/L2 over UDP/TCP)

Bezpečnosť na sieťovej vrstve

IPSec transportný mód

medzi hlavičku 3. a 4. vrstvy sa vloží hlavička AH/ESP

AH – ochrana integrity údajov sieťovej, transportnej a aplikačnej vrstvy

ESP – ochrana integrity a/alebo dôvernosti údajov transportnej a aplikačnej vrstvy

obsah paketu od hlavičky 4. vrstvy sa môže šifrovať

tunelový mód (IPSec, OpenVPN)

celý IP paket (príp. celý rámec 2. vrstvy) sa (po zašifrovaní) pošle v novom pakete

Bezpečnosť na transportnej vrstve

SSL (Secure Socket Layer), TLS (Transport Layer Security)

- medzi transportnou a aplikačnou vrstvou
- zabezpečuje autentifikáciu servera a (voliteľne) klienta
 - X.509 certifikáty –
 - Certifikát obsahuje verejný kľuč, identitu subjektu, platnosť (do kedy je platný, po čase ich treba vymeniť)
 - certifikát je jedna z prvých vecí ktoré server pošle klientovi, ale ten potrebujem overiť či je platný...preto sa overuje podpis ešte vyššej autority, ale na to potrebujem vedieť jej verejný kľuč...takto to ide hore-hore až na najvyššiu autoritu. tá najvyššia má potom verejný kľuč a súkromný kľuč
 - preto musím mať tieto authority nainštalované z overeného zdroja. (napr. webové preliadače keď nainštalujeme, tak on si sam prinesie tieto certifikáty...a umožňuje pridávať a odoberať rôzne certifikáty)
- zabezpečuje vzájomné dohodnutie kľúčov
- šifrovanie, kontrola integrity a autentickosti prenášaných dát
- treba zabezpečiť bezpečnú distribúciu cert. CA

Bezpečnosť na aplikačnej vrstve

end-to-end security

e-mail

PGP, S/MIME

vzdialené prihlasovanie

ssh – (protokol, ktorý rieši bezpečnosť)

autentifikácia používateľov v aplikáciach

heslá, jednorazové heslá, SMS-kódy, ...

Bezpečnosť elektronickej pošty

- správa elektronickej pošty == pohľadnica písaná na stroji
 - môže čítať každý, kto ju cestou vidí, nemožno dôverovať informácii o odosielateľovi, nemožno dôverovať obsahu
- riešenie:
 - dôvernosť – šifrovanie, integrita a autentickosť – elektronický podpis
- PGP (Pretty Good Privacy)
 - treba zabezpečiť bezpečnú distribúciu verejných kľúčov
 - vzájomná dôvera používateľov a podpisovanie kľúčov
- S/MIME (Secure Multipurpose Internet Mail Extensions)
 - použitie X.509 certifikátov
 - treba zabezpečiť bezpečnú distribúciu cert. CA

Bezpečnosť elektronickej pošty

- komunikácia so serverom

 - SMTP – odosielanie pošty

 - POP3, IMAP – čítanie pošty

 - nechráni komunikáciu

 - heslá sú ľahko odhaliteľné

- riešenie

 - SSL, TLS

 - SMTPS, POP3S, IMAPS

Bezpečnosť webu

- Protokol HTTP:

nezabezpečuje ochranu komunikácie, ktokoľvek môže vidieť to, čo vidím ja, ktokoľvek môže vidieť, čo odosielam, ktokoľvek môže zmeniť to, čo vidím, ktokoľvek môže zmeniť to, čo odosielam

- Riešenie:

SSL, TLS – HTTPS

- Problémy:

- bezpečná distribúcia certifikátu CA
- kontrola mena servera v certifikáte
- SSLv2 (malo by sa zakázať)
 - pripúšťa aj slabé šifry
- ignorovanie upozornení browsera

- telnet

žiadna ochrana

- ssh

- šifrovanie, kontrola integrity, autentifikácia servera
- umožňuje tunelovať ďalšie spojenia
napr. X11, VNC, SMTP, POP3, IMAP
- treba zabezpečiť bezpečnú distribúciu verejných kľúčov serverov
- neveriť slepo verejnému kľúču servera
- openssh (UNIX, Linux, Cygwin), PuTTY (Windows)

Bezpečnosť ftp

- protokol FTP

- nezabezpečuje žiadnu ochranu (heslá, prenášané dáta)
- má problémy so stateless firewallmi
- statefull firewally musia podporovať ftp

- scp, sftp

- náhrady využívajúce ssh

- openssh, PuTTY, WinSCP (Windows)